BỘ BÀI TẬP THỰC HÀNH NÂNG CAO – UBUNTU LINUX, MẠNG, VPN VÀ DOCKER

BÁO CÁO BÀI 2
THIẾT LẬP WHITELIST VÀ BLACKLIST TRUY CẬP THEO VPN
Phần: Sản phẩm và minh chứng

Sinh viên	Trần Đức Việt Anh
Server	Hostname `maychucuavietanh` · Ubuntu 24.04.1 LTS · kernel 6.8.0-139-generic
IP công cộng (eth0)	103.216.118.115
Cổng SSH	24700/tcp
IP VPN cá nhân	37.19.205.163
Công cụ firewall	UFW (Uncomplicated Firewall)
Hồ sơ minh chứng kèm theo	`05_Minh_chung_Bai2.docx` (ảnh MC-01 đến MC-06)

Thông số chưa được cấp tại thời điểm lập báo cáo

Thông số	Giá trị	Hạng mục phụ thuộc
`<VPN_IP_GIANG_VIEN>`	Chờ giảng viên cấp	Rule SSH hỗ trợ kỹ thuật, TC2
`<VPN_SUBNET_LOP>`	Chờ giảng viên cấp	Rule dịch vụ thử nghiệm, TC1b, TC3
`<PORT_DICH_VU>`	Chờ giảng viên cấp	Rule dịch vụ thử nghiệm, TC1b
`<IP_BLACKLIST_01..03>`	Chờ giảng viên cấp	Rule blacklist, TC5

Tóm tắt tiến độ

Hạng mục	Trạng thái	Minh chứng
Sao lưu cấu hình firewall trước khi thay đổi	Hoàn thành	MC-01
Default deny incoming / allow outgoing	Hoàn thành	MC-02
Whitelist SSH cho VPN cá nhân, có ghi log	Hoàn thành	MC-02, MC-04, MC-05
Đóng SSH từ Internet công cộng	Hoàn thành	MC-02, MC-03, MC-06
Whitelist SSH cho VPN giảng viên	Chờ thông số	—
Dịch vụ `<PORT_DICH_VU>` chỉ cho `<VPN_SUBNET_LOP>`	Chờ thông số	—
Blacklist 03 địa chỉ IP	Chờ thông số	—
Kiểm tra tính bền vững sau reboot	Chưa thực hiện	—

1. SẢN PHẨM 1 – MA TRẬN WHITELIST/BLACKLIST VÀ THỨ TỰ ƯU TIÊN

1.1. Ma trận truy cập

Đích của mọi luồng inbound là server 103.216.118.115. Cột "Thứ tự" thể hiện nhóm ưu tiên trong chuỗi xử lý của UFW; trong cùng một nhóm, rule đứng trước được xét trước.

Thứ tự	Nguồn	Cổng / Giao thức	Hành động	Log	Lý do	Trạng thái
before.rules	Loopback (lo)	Mọi	ALLOW	Không	Tiến trình nội bộ giao tiếp qua 127.0.0.1	Mặc định UFW
before.rules	Kết nối ESTABLISHED, RELATED	Mọi	ALLOW	Không	Gói trả lời cho kết nối đã được phép; server vẫn cập nhật gói, phân giải DNS	Mặc định UFW
before.rules	Mọi nguồn	ICMP echo-request	ALLOW	Không	Phục vụ chẩn đoán bằng ping; giữ theo mặc định	Mặc định UFW
1 – Blacklist	<IP_BLACKLIST_01> <IP_BLACKLIST_02> <IP_BLACKLIST_03>	Mọi	DENY	Có	Nguồn không tin cậy; đặt đầu danh sách để thắng mọi rule allow	Chờ thông số
2 – Allow	37.19.205.163/32 (VPN cá nhân)	24700/tcp (SSH)	ALLOW	Có	Quản trị server qua VPN	Đã triển khai
2 – Allow	<VPN_IP_GIANG_VIEN>/32	24700/tcp (SSH)	ALLOW	Có	Hỗ trợ kỹ thuật, nghiệm thu	Chờ thông số
2 – Allow	<VPN_SUBNET_LOP>	<PORT_DICH_VU>/tcp	ALLOW	Không	Dịch vụ thử nghiệm chỉ dành cho lớp	Chờ thông số
2 – Allow (có từ trước)	Anywhere	8080/tcp	ALLOW	Không	Rule có sẵn khi nhận bàn giao, chưa xác định mục đích	Cần giảng viên xác nhận
Cuối – Default	Mọi nguồn còn lại (Internet, VPN khác)	Mọi	DENY	Có	Nguyên tắc từ chối mặc định	Đã triển khai
Cuối – Default	Server (outbound)	Mọi	ALLOW	Không	Server cần kết nối ra ngoài	Đã triển khai

> **Về rule 8080/tcp:** rule này đang mở cho mọi nguồn. Nếu 8080 chính là `<PORT_DICH_VU>` thì rule vi phạm chính sách và phải được thay bằng rule chỉ cho `<VPN_SUBNET_LOP>`; nếu không có dịch vụ nào dùng cổng này thì xóa. Bổ sung: kết quả `ss -tlnp | grep :8080`

1.2. Giải thích thứ tự ưu tiên

Mỗi gói tin inbound đi qua UFW theo trình tự cố định sau:

1. **before.rules:** chấp nhận loopback, gói thuộc kết nối ESTABLISHED/RELATED, ICMP chẩn đoán.
2. **User rules** theo thứ tự trong `ufw status numbered`. Gói khớp rule đầu tiên thì dừng xét, các rule phía sau không còn tác dụng với gói đó.
3. **after.rules và các chain logging.**
4. **Default policy (deny incoming):** gói không khớp rule nào bị DROP và ghi log với nhãn `[UFW BLOCK]`.

Từ trình tự này, chính sách được thiết kế với các hệ quả sau:

- **Blacklist phải đứng trước mọi rule allow.** Giả sử một IP blacklist thuộc `<VPN_SUBNET_LOP>` mà rule deny nằm sau rule allow theo subnet, gói tin sẽ khớp rule allow trước và lọt qua. Vì vậy blacklist được thêm bằng `ufw insert 1 deny ...`; lệnh `ufw deny ...` sẽ thêm rule xuống cuối danh sách.
- **Kết nối đã thiết lập được chấp nhận trước cả blacklist.** Một phiên mở trước thời điểm IP bị chặn vẫn tiếp tục hoạt động; muốn cắt ngay phải dùng `ss -K dst <IP>`.
- **Whitelist khớp theo IP nguồn mà server nhìn thấy.** Lưu lượng từ VPN cá nhân đến server qua eth0 với IP nguồn 37.19.205.163, là địa chỉ thoát của VPN. Điều này được xác nhận bằng `curl ifconfig.me` trên máy client (MC-04) và trường `SRC` trong log firewall (MC-05), nên rule SSH được viết theo địa chỉ này.
- **Rule deny của UFW dùng DROP.** Client bị chặn phải chờ đến timeout thay vì nhận "connection refused", do đó không biết cổng có dịch vụ hay không (MC-03).

2. SẢN PHẨM 2 – CẤU HÌNH FIREWALL TRƯỚC VÀ SAU KHI TRIỂN KHAI

2.1. Sao lưu cấu hình trước khi thay đổi (MC-01)

Trước khi sửa bất kỳ rule nào, trạng thái firewall được lưu vào thư mục `~/Cau_Hinh` và toàn bộ thư mục `/etc/ufw` được sao lưu sang `/root`.

Lệnh	Tệp kết quả	Mục đích
`ufw status verbose > ufw_status_verbose.txt`	ufw_status_verbose.txt	Trạng thái, default policy, mức log
`ufw status numbered > ufw_status_numbered.txt`	ufw_status_numbered.txt	Danh sách rule kèm số thứ tự
`iptables-save > iptables-save.txt`	iptables-save.txt	Rule IPv4 thực tế ở tầng kernel
`ip6tables-save > ip6tables-save.txt`	ip6tables-save.txt	Rule IPv6 thực tế ở tầng kernel

Lệnh	Tệp kết quả	Mục đích
`cp -a /etc/ufw /root/ufw-backup-$(date +%F)`	/root/ufw-backup-<ngày>	Bản sao đầy đủ /etc/ufw, dùng để khôi phục

> **Sự cố phát sinh:** lệnh `cp -a /etc/ufw /etc/default/ufw` bị thiếu thư mục đích, nên `cp` hiểu là chép thư mục `/etc/ufw` thành `/etc/default/ufw`. Vì `/etc/default/ufw` là một file thường, `cp` báo lỗi "cannot overwrite non-directory" và dừng lại, không có file nào bị ghi đè. Có thể xác nhận bằng `ls -l /etc/default/ufw`.
> **Khắc phục:** bản sao đầy đủ của `/etc/ufw` đã được tạo ở lệnh kế tiếp và được đưa vào hồ sơ bằng `cp -a /root/ufw-backup-<ngày> ~/Cau_Hinh/truoc_etc_ufw`. Default policy trước khi thay đổi được ghi lại trong `ufw_status_verbose.txt`.

2.2. Rule trước khi triển khai

Theo kết quả `ufw show added` trong MC-02, trước khi triển khai server có ba rule do người dùng thêm:

Rule	Hành động	Nguồn	Nhận xét
8080/tcp	ALLOW IN	Anywhere	Chưa xác định mục đích
24700	ALLOW IN	Anywhere	Mở SSH cho mọi địa chỉ, gồm cả TCP và UDP vì không ghi giao thức; SSH không cần UDP
24700/tcp	ALLOW IN	Anywhere	Mở SSH cho mọi địa chỉ Internet

Hiện trạng này khớp với bối cảnh đề bài: cổng SSH truy cập được từ bất kỳ địa chỉ Internet nào.

2.3. Các bước triển khai (MC-02)

Bước	Lệnh	Mục đích / kết quả
1	`ufw default deny incoming`	Từ chối mọi kết nối vào không có rule cho phép
2	`ufw default allow outgoing`	Cho phép server chủ động kết nối ra ngoài
3	`ufw allow in log from 37.19.205.163 to any port 24700 proto tcp comment 'SSH SV'`	Thêm whitelist SSH cho VPN cá nhân, có ghi log và chú thích
4	`ufw show added` và `ufw status numbered`	Soát danh sách rule; rule mới nằm ở vị trí [4]
5	`ufw delete 2`	Xóa rule `allow 24700` (TCP và UDP, mọi nguồn)
6	`ufw status numbered`	Kiểm tra lại: số thứ tự đã dịch, rule `24700/tcp Anywhere` chuyển lên vị trí [2]
7	`ufw delete 2`	Xóa rule `allow 24700/tcp` (mọi nguồn)

> **Nguyên tắc an toàn đã áp dụng:** whitelist cho VPN cá nhân được thêm ở bước 3, trước khi xóa các rule mở rộng ở bước 5 và 7, nên đường quản trị qua VPN luôn tồn tại trong suốt quá trình. Sau mỗi lần xóa đều xem lại `ufw status numbered` vì số thứ tự thay đổi; UFW cũng hiển thị nội dung rule và yêu cầu xác nhận (y|n) trước khi xóa, giúp tránh xóa nhầm whitelist.

2.4. Rule sau khi triển khai

Số	To	Action	From	Ghi chú
[1]	8080/tcp	ALLOW IN	Anywhere	Chờ xác nhận mục đích
[2]	24700/tcp	ALLOW IN	37.19.205.163	(log) # SSH SV

Bổ sung: tệp `ufw status numbered` và `ufw status verbose` sau cùng, lưu tại 03_Cau_hinh/sau/

2.5. So sánh trước và sau

Tiêu chí	Trước	Sau
Nguồn được SSH vào cổng 24700	Mọi địa chỉ Internet	Chỉ 37.19.205.163
Giao thức mở trên cổng 24700	TCP và UDP	Chỉ TCP
Ghi log kết nối SSH hợp lệ	Không	Có (`[UFW ALLOW]`)
Default incoming	<theo ufw_status_verbose.txt>	deny, có log `[UFW BLOCK]`
Default outgoing	<theo ufw_status_verbose.txt>	allow
Cổng 8080/tcp	Mở cho mọi nguồn	Giữ nguyên, chờ xác nhận
Blacklist	Không có	Chờ thông số
Dịch vụ theo subnet VPN	Không có	Chờ thông số

3. SẢN PHẨM 3 – BIÊN BẢN KIỂM THỬ TRUY CẬP

Các trường hợp kiểm thử SSH dùng cùng một bộ lệnh trên máy client (Windows):

```
curl ifconfig.me
ssh -p 24700 -o ConnectTimeout=5 root@103.216.118.115
```

`curl ifconfig.me` ghi lại IP nguồn thực tế mà server sẽ nhìn thấy. Tham số `ConnectTimeout=5` giới hạn thời gian chờ, giúp phân biệt rõ trường hợp bị chặn.

TC	Nguồn truy cập	IP nguồn thực tế	Kỳ vọng	Kết quả thực tế	Đánh giá	Minh chứng
TC1	VPN cá nhân (laptop Acer)	37.19.205.163	SSH thành công	Hiện yêu cầu mật khẩu, đăng nhập thành công; banner ghi thời điểm 22:26:19 ngày 10/09/2026. Firewall ghi `[UFW ALLOW]` lúc 22:26:12	**Đạt**	MC-04, MC-05
TC1b	VPN cá nhân tới `<PORT_DICH_VU>`	37.19.205.163	Truy cập được dịch vụ	—	Chờ thông số	—
TC2	VPN giảng viên	<VPN_IP_GIANG_VIEN>	SSH thành công	—	Chờ thông số	—
TC3	VPN khác, ngoài whitelist cá nhân	<IP>	SSH bị từ chối	—	Chưa thực hiện	—

TC	Nguồn truy cập	IP nguồn thực tế	Kỳ vọng	Kết quả thực tế	Đánh giá	Minh chứng
TC4	Internet công cộng, không qua VPN (máy DELL)	27.79.217.108	SSH bị từ chối	"Connection timed out" sau 5 giây. Firewall ghi `[UFW BLOCK]` với DPT=24700	**Đạt**	MC-03, MC-06
TC5	IP thuộc blacklist	<IP_BLACKLIST_0x>	Mọi cổng bị chặn, có log	—	Chờ thông số	—
TC6	Sau reboot server	—	Rule giữ nguyên, đúng thứ tự	—	Chưa thực hiện	—

Tổng hợp: 2 trường hợp đạt, 0 trường hợp không đạt, 5 trường hợp chờ thông số hoặc chưa thực hiện.

Nhận xét: TC1 và TC4 dùng cùng một lệnh tới cùng một đích, chỉ khác IP nguồn, nhưng cho kết quả trái ngược. Điều này chứng tỏ firewall phân biệt truy cập theo nguồn đúng chính sách. Ở TC4, client nhận timeout chứ không phải "connection refused", nghĩa là gói SYN đã bị firewall loại bỏ trước khi đến được tiến trình sshd.

4. SẢN PHẨM 4 – LOG KẾT NỐI ĐƯỢC PHÉP VÀ BỊ TỪ CHỐI

Các bản ghi dưới đây do kernel ghi khi gói tin khớp rule có ghi log hoặc bị default policy chặn. Bổ sung: lệnh đã dùng để trích log

4.1. Kết nối được phép (MC-05)

```
2026-09-10T22:26:12.973023+07:00 maychucuavietanh kernel: [UFW ALLOW] IN=eth0 OUT=
MAC=fa:16:3e:0a:b1:d6:e0:30:f9:a8:a9:a0:08:00 SRC=37.19.205.163 DST=103.216.118.115 LEN=52
TOS=0x00 PREC=0x00 TTL=121 ID=43730 DF PROTO=TCP SPT=53749 DPT=24700 WINDOW=65535 RES=0x00 SYN
URGP=0
```

Trường	Giá trị	Ý nghĩa
Thời gian	2026-09-10 22:26:12 (+07:00)	Khớp với phiên đăng nhập ở MC-04 (banner lúc 22:26:19)
Hostname	`maychucuavietanh`	Server ghi log
Nhãn	`[UFW ALLOW]`	Gói khớp rule allow có tùy chọn log (rule SSH SV)
IN / OUT	IN=eth0, OUT= (trống)	Gói vào qua interface công cộng; đích là chính server, không phải gói chuyển tiếp
MAC	`fa:16:3e:0a:b1:d6` : `e0:30:f9:a8:a9:a0` : `08:00`	MAC eth0 của server : MAC thiết bị gửi liền kề (gateway) : loại khung IPv4
SRC	37.19.205.163	IP VPN cá nhân, thuộc whitelist
DST	103.216.118.115	IP công cộng của server
PROTO / SPT / DPT	TCP / 53749 / 24700	Từ cổng nguồn tạm của client tới cổng SSH
Cờ TCP	SYN	Gói mở kết nối mới, được firewall xét theo rule

4.2. Kết nối bị từ chối (MC-06)

```
2026-09-09T22:54:16.340401+07:00 cs-linux-20260907090630107 kernel: [UFW BLOCK] IN=eth0 OUT=
MAC=fa:16:3e:0a:b1:d6:e0:30:f9:a8:a9:a0:08:00 SRC=27.79.217.10… DST=103.216.118.115 LEN=52
TOS=0x00 PREC=0x00 TTL=116 ID=3493 DF PROTO=TCP SPT=51202 DPT=24700 WINDOW=65535 RES=0x00 SYN
URGP=0
```

Trường	Giá trị	Ý nghĩa
Thời gian	2026-09-09 22:54:16 (+07:00)	Thời điểm gói tin bị chặn
Hostname	`cs-linux-20260907090630107`	Hostname của server tại thời điểm ghi log (xem ghi chú bên dưới)
Nhãn	`[UFW BLOCK]`	Gói không khớp rule allow nào, bị default deny incoming chặn và ghi log
IN	eth0	Gói đến từ Internet qua interface công cộng
MAC	Trùng với MC-05	Cùng interface eth0 của cùng server, cùng gateway
SRC	27.79.217.10… (ảnh bị cắt ở mép phải)	IP Internet công cộng ngoài whitelist; khớp phần đầu với IP máy thử nghiệm ở MC-03 (27.79.217.108)
DST	103.216.118.115	IP công cộng của server
PROTO / SPT / DPT	TCP / 51202 / 24700	Thử kết nối tới cổng SSH
Cờ TCP	SYN	Lần thử mở kết nối; gói bị DROP nên client chờ đến timeout

Ghi chú: hostname trong bản ghi (`cs-linux-20260907090630107`) khác hostname hiện tại. Trường DST và MAC của eth0 trùng với bản ghi ở MC-05, xác nhận đây là cùng một server. Bổ sung: thời điểm đổi hostname sang maychucuavietanh

4.3. Kiểm soát dung lượng log

UFW gắn giới hạn tần suất cho các rule ghi log (mặc định 3 bản ghi mỗi phút, burst 10) và file `/var/log/ufw.log` được logrotate xoay vòng định kỳ. Nhờ vậy, việc bị dò cổng liên tục từ Internet không làm log tăng mất kiểm soát. Bổ sung: kết quả `iptables -S | grep limit` và `cat /etc/logrotate.d/ufw`

5. SẢN PHẨM 5 – QUY TRÌNH KHÔI PHỤC KHI TỰ KHÓA SSH

Quy trình áp dụng khi không còn phiên SSH nào vào được server, ví dụ whitelist sai IP, IP thoát của VPN thay đổi, xóa nhầm rule hoặc sửa sai `sshd_config`. Web Console (VNC) của nhà cung cấp kết nối thẳng tới màn hình máy chủ, không đi qua mạng của server, nên không bị firewall chặn.

Nguyên tắc: không dùng `ufw disable` để lấy lại quyền truy cập; chỉ mở đúng nguồn cần thiết. Trước mỗi lần thay đổi đã có bản sao lưu `/root/ufw-backup-<ngày>` để khôi phục.

Bước 1 – Truy cập Web Console (VNC)

Thực hiện ở đâu: trình duyệt trên máy cá nhân.

Đăng nhập vào trang quản trị máy chủ của nhà cung cấp, mở giao diện điều khiển Console/VNC trực tiếp.

Xác nhận thành công: màn hình đen hiển thị dấu nhắc chờ đăng nhập `login:`.

Bước 2 – Đăng nhập tài khoản cục bộ

Thực hiện ở đâu: cửa sổ VNC.

Nhập tên người dùng (`root`), tự gõ tay mật khẩu rồi nhấn Enter. Các ký tự mật khẩu sẽ không hiển thị trên màn hình; nhiều giao diện VNC không hỗ trợ dán nên cần gõ trực tiếp.

Xác nhận thành công: hệ thống hiển thị dấu nhắc lệnh, ví dụ `root@maychucuavietanh:~#`.

Bước 3 – Khắc phục nguyên nhân gây khóa

Thực hiện ở đâu: cửa sổ VNC.

Tùy vào thao tác trước đó đã gây ra lỗi, chạy lệnh xử lý tương ứng:

Lỗi do firewall: xác định IP hiện tại của máy cá nhân (`curl ifconfig.me`), sau đó chỉ mở SSH cho đúng IP đó và đặt rule lên đầu danh sách:

```
ufw insert 1 allow from <IP_HIEN_TAI> to any port 24700 proto tcp comment 'KHOI PHUC'
```

Nếu cấu hình bị hỏng nhiều, có thể đưa về trạng thái trước triển khai từ bản sao lưu, sau đó áp dụng lại chính sách:

```
cp -a /root/ufw-backup-<ngay>/user.rules /root/ufw-backup-<ngay>/user6.rules /etc/ufw/
ufw reload
```

Lỗi do sửa sai cấu hình SSH: mở file và sửa lại cho đúng, rồi kiểm tra cú pháp (không in ra gì nghĩa là hợp lệ):

```
nano /etc/ssh/sshd_config
sshd -t
```

Xác nhận thành công: `ufw status numbered` thấy rule cho IP hiện tại ở vị trí đầu; `ss -tlnp | grep 24700` thấy sshd đang lắng nghe.

Bước 4 – Tải lại dịch vụ và kết nối lại

Thực hiện ở đâu: cửa sổ VNC, sau đó Terminal trên máy cá nhân.

Nếu vừa sửa cấu hình SSH, khởi động lại dịch vụ:

```
systemctl restart ssh
```

Nếu có đổi cổng SSH và server dùng socket activation (mặc định trên Ubuntu 24.04, kiểm tra bằng `systemctl is-active ssh.socket`), cần nạp lại cấu hình systemd:

```
systemctl daemon-reload
systemctl restart ssh.socket
```

Giữ nguyên phiên VNC, mở Terminal trên máy cá nhân và thử kết nối SSH lại từ đầu:

```
ssh -p 24700 root@103.216.118.115
```

Sau khi vào được: rà lại `ufw status numbered`, xóa rule tạm `KHOI PHUC` nếu IP đó không thuộc whitelist chính thức, chạy lại ma trận kiểm thử và ghi sự cố vào báo cáo.

Xác nhận thành công: đăng nhập SSH thành công từ máy cá nhân; ma trận kiểm thử cho kết quả như trước sự cố.

6. HẠNG MỤC CÒN LẠI VÀ RỦI RO

- **Hoàn thiện chính sách khi có thông số:** thêm blacklist bằng `ufw insert 1`, whitelist SSH cho giảng viên và rule dịch vụ theo `<VPN_SUBNET_LOP>`; thực hiện TC1b, TC2, TC3, TC5.

- **Cổng 8080/tcp đang mở cho mọi nguồn:** xác định tiến trình đang lắng nghe, sau đó xóa rule hoặc giới hạn theo `<VPN_SUBNET_LOP>`.
- **Kiểm thử sau reboot (TC6):** lưu `ufw status numbered` trước và sau reboot, so sánh bằng `diff` để chứng minh rule không đổi thứ tự.
- **Whitelist phụ thuộc IP thoát của VPN:** nếu nhà cung cấp VPN đổi địa chỉ 37.19.205.163, SSH sẽ bị khóa. Khi đó áp dụng quy trình ở Sản phẩm 5.
- **Đăng nhập SSH đang dùng root và mật khẩu (MC-04):** đề xuất tạo tài khoản quản trị riêng có sudo, dùng SSH key, sau đó đặt `PermitRootLogin no` và `PasswordAuthentication no`. Chỉ thực hiện sau khi đã đăng nhập thử thành công bằng tài khoản mới ở một phiên riêng.
- **IPv6:** `ufw status` hiện không có rule `(v6)`. Cần kiểm tra server có địa chỉ IPv6 công cộng hay không (`ip -6 addr`) và giá trị `IPV6` trong `/etc/default/ufw`, để bảo đảm SSH qua IPv6 cũng được kiểm soát.